

DeFi 攻击十年：2017-2026 模式演化

陈世强 | 2026年7月 | github.com/shunfeng8421

摘要

本文分析了 824 个已确认的 DeFi 安全事件 (2017-2026)，是同类研究中规模最大的实证研究。攻击模式从高额闪电贷利用 (峰值超 \$600M) 演化为小规模权限bug (2025年中位数 \$50K)。识别出 17 种独特攻击模式；闪电贷+预言机操纵仍最具破坏性 (24%案例, 60%损失)。DeFi 风险指数 (损失/TVL) 从 2020 年的 3.33% 降至 2025 年的 2.33%。2026 年出现了精度错误+后门+会计不一致的新型攻击类别。大协议在硬化, 小项目仍然脆弱。

1. 数据与分类

数据来源: DeFiHackLabs (824个 PoC 合约)、Rekt News、安全公司报告 (CertiK、慢雾、派盾、BlockSec)。我们建立了 17 模式分类体系, 涵盖闪电贷+预言机 (#1)、重入 (#2)、ERC-4626 通胀 (#5)、借贷清算 (#6)、AMM 操纵 (#7)、治理攻击 (#8)、管理员密钥滥用 (#13)、签名重放 (#27)、跨链 (#34)、精度损失 (#46) 等。

2. 时间演化

2017-2018: 合约 bug 主导 (Parity \$170M)。2020: 闪电贷兴起 (bZx \$50M)。2021: 闪电贷+预言机高峰 (Poly Network \$610M)。2022: 跨链桥时代 (Ronin \$600M)。2023: 借贷攻击激增 (Euler \$197M)。2024: 多向量组合 (Hedgex \$48M)。2025: 权限 bug 主导 (中位数 \$50K)。2026: 精度+后门+会计 (Bybit \$1.5B)。

3. 风险指数

风险指数 = 年损失总额 / TVL。从 3.33% (2020) 降至 2.33% (2025), 下降了 30%。尽管攻击增多, TVL 增长远超损失增长。2030年预测: 若趋势持续, 风险指数将低于 1%。

4. 闪电贷的主导地位

闪电贷促成了 24% 的攻击, 却造成了 60% 的损失 (\$6B+)。该机制允许原子化执行、预言机操纵和无限资本。TWAP 和 Chainlink 的采用使新闪电贷事件自 2023 年以来减少了 40%。

5. 2026 年的新变化

2026 年上半年出现了新趋势: 精度错误 + 蓄意后门 + 会计不一致。这些难以被自动化工具检测, 需要业务逻辑的深入理解。代表案例: Bybit \$1.5B (社会工程)、JoeAgent \$45K (AI代理CEI)、AIDC (代币燃烧操纵)。

结论

DeFi 安全性已有可衡量的改善。但攻击面正在分裂——大协议硬化, 小项目仍暴露。下一个前沿: 检测后门和复杂会计操纵。数据集: [10.5281/zenodo.21382653](https://zenodo.org/record/21382653)